

MAPLECARE HEALTH SERVICES

TECHNOLOGY RISK ASSESSMENT,
CONTROL ASSURANCE AND
REMEDiation REVIEW

Engagement Charter

Prepared by	Breck Agyekum Technology Risk and GRC Analyst
Document status	Final
Version	1.0
Assessment period	Q1 2026
Classification	Professional portfolio Simulated data

ENGAGEMENT NOTICE

MapleCare Health Services is fictional. All risks, controls, evidence, findings, testing results, dates, management actions and records are simulated for professional portfolio demonstration. No real patient, employee, client or company data is used.

1. Engagement Overview

MapleCare Health Services is a fictional Canadian healthcare organization with approximately 150 employees. The organization depends on Microsoft 365, SharePoint, a patient records system, an HR management platform, employee endpoint devices, backup services and a third-party billing portal to support clinical, administrative and financial operations.

MapleCare processes sensitive patient, employee, billing and internal business information. Management requires a clearer view of material technology risks, existing controls, control gaps, remediation priorities and audit readiness.

This engagement applies a structured technology risk assessment and control assurance approach to support risk-based decision-making, remediation oversight and management reporting.

2. Business Problem

MapleCare does not maintain a complete and centralized view of its technology and cybersecurity risks. Risk information is distributed across departments, control ownership is not always clearly defined, and evidence supporting key controls is not consistently retained.

These conditions may limit management's ability to identify material risks, prioritize remediation, monitor control performance, assess third-party exposure, demonstrate audit readiness and report technology risk consistently to leadership.

3. Engagement Objective

The objective of the review is to identify and assess MapleCare's material technology and cybersecurity risks, evaluate the design and operating effectiveness of related controls, document control weaknesses, and establish accountable remediation and management-reporting processes.

The review provides management with a documented view of critical systems and business processes, prioritized technology risks, control ownership, testing results, significant findings, remediation requirements and decision-focused risk reporting.

4. Scope

• Identity and access management	• Microsoft 365 and SharePoint security
• Patient-record access	• Employee onboarding and offboarding
• Privileged access management	• Endpoint security
• Patch and vulnerability management	• Backup and recovery
• Incident response	• Security awareness and training
• Data classification and handling	• Third-party and vendor risk
• Business continuity and resilience	• Technology risk governance
• Audit evidence management	

5. Out of Scope

• Penetration testing	• Vulnerability scanning
• Source-code review	• Production-system changes
• Legal or regulatory opinions	• Formal certification or attestation
• Live access to real patient, employee, client or company data	• Implementation of technical remediation actions

6. Assessment Approach

1. Define the review scope, objectives, stakeholders and deliverables.
2. Understand the business and technology environment.
3. Identify critical systems, processes, data, owners and dependencies.
4. Identify and assess technology, cybersecurity, privacy, resilience and third-party risks.
5. Document existing controls and control gaps.
6. Define control objectives and recommended control activities.
7. Map controls to relevant NIST and ISO references.
8. Define and execute control-testing procedures.
9. Review evidence and assess design and operating effectiveness.
10. Document findings, root causes and management actions.
11. Track remediation, closure evidence and retesting.
12. Prepare executive risk reporting and a management summary.

7. Risk Assessment Method

Risks are evaluated using likelihood and business impact. Business impact considers patient and service delivery, privacy and confidentiality, operational disruption, financial consequences, regulatory or contractual exposure, and reputational harm.

Each risk is documented with a unique identifier, affected asset or process, risk statement, likelihood and impact ratings, existing controls, control gaps, risk ownership, treatment decision and status.

8. Framework Alignment

The review uses NIST Cybersecurity Framework 2.0, NIST SP 800-53 Revision 5 and ISO/IEC 27001:2022 to support risk identification, control design, testing and framework traceability. Framework mapping supports the assessment and does not imply certification or formal compliance.

9. Stakeholders and Responsibilities

Stakeholder	Responsibility
Executive Sponsor	Provides oversight and supports major risk decisions.
Technology Risk Lead	Directs the review and approves key deliverables.
IT Manager	Provides technology information, control evidence and remediation ownership.
Operations Manager	Supports business-process assessment and continuity planning.
HR Manager	Supports onboarding, offboarding, training and access-control reviews.
Finance Manager	Supports billing-vendor and financial-process assessment.
Clinic Manager	Supports patient-record access and clinical-system assessment.
Control Owners	Validate controls, provide evidence and manage remediation actions.

10. Analyst Responsibilities

- Coordinate review activities and stakeholder engagement.
- Document the business and technology environment.
- Maintain the asset and process inventory.
- Develop and maintain the Technology Risk Register.
- Document existing controls and control gaps.
- Prepare the Risk and Control Matrix.
- Define and execute control-testing procedures.
- Review evidence and document exceptions.
- Assess control design and operating effectiveness.
- Develop findings and remediation actions.
- Define closure-evidence and retesting requirements.
- Prepare management-level risk reporting.
- Maintain traceability between risks, controls, evidence, findings and actions.

11. Engagement Deliverables

#	Deliverable	Purpose
1	Engagement Charter	Defines the objective, scope, stakeholders, approach and governance.
2	Business and Technology Profile	Documents the operating environment, systems, data and dependencies.
3	Asset and Process Inventory	Identifies important systems, processes, ownership, sensitivity and criticality.
4	Technology Risk Register	Records and prioritizes technology and cybersecurity risks.
5	Risk and Control Matrix	Links risks to controls, owners, evidence, testing procedures and frameworks.
6	Control Testing and Evidence Package	Assesses control design and operating effectiveness.
7	Remediation Tracker	Tracks findings, owners, target dates, evidence, validation and retesting.
8	Executive Risk Reporting and Management Summary	Consolidates risk exposure, control effectiveness, remediation progress and management priorities.

12. Governance and Review

- Risks and control descriptions are validated with relevant owners.
- High and critical risks are escalated for management review.
- Evidence requests, test procedures and conclusions are documented.
- Remediation actions include accountable owners and target dates.
- Completed actions require closure evidence and successful retesting before final closure.
- Material changes to scope, risk ratings or findings are recorded and approved.

13. Assumptions

- Stakeholders provide complete and accurate information.
- System and process owners are available for review.
- Relevant policies, reports and control evidence can be provided.
- Conclusions are based on information available during the assessment period.
- Fictional data and scenarios are used for professional portfolio demonstration.

14. Limitations

This engagement is a portfolio-based simulation and does not represent an audit, certification, legal review or formal assurance opinion. No real patient, employee, client or company data is used. Conclusions are based on simulated records and evidence prepared for the engagement scenario.

15. Success Measures

- 15 material technology and cybersecurity risks documented and prioritized.
- 15 related controls mapped to applicable NIST and ISO references.
- Control-testing procedures and evidence requirements defined and executed.
- Design and operating effectiveness assessed and documented.
- Findings assigned severity, ownership and management actions.
- Closure-evidence and retesting requirements documented.
- Management reporting prepared to communicate risk exposure and remediation priorities.

16. Document Approval and Portfolio Validation

Role	Name	Status	Date
Technology Risk and GRC Analyst	Breck Agyekum	Prepared	July 2026
Quality Review	Portfolio simulation	Completed	July 2026

Stakeholder representation

Executive Sponsor, IT Manager and Operations Manager roles are represented through simulated stakeholder requirements, evidence requests, management responses and remediation ownership.

Portfolio Notice

MapleCare Health Services is a fictional Canadian healthcare organization created for professional portfolio demonstration. All systems, risks, controls, evidence, findings and records are simulated.